

Отчет по тестированию защищенности

Александр Дорофеев, CISSP, CISA, CISM

Echelon Eyes



@ECHELONEYES

Записи и презентации будут опубликованы в телеграм-канале Echelon Eyes

<https://t.me/EchelonEyes>

Предупреждение

- Рассматриваемые в курсе приемы тестирования защищенности можно отрабатывать только в собственной виртуальной лаборатории в отношении тестовых машин.
- Использование приемов в отношении реальных информационных ресурсов может подпадать под одну из следующих статей УК РФ:
 - УК РФ Статья 272. Неправомерный доступ к компьютерной информации
 - УК РФ Статья 273. Создание, использование и распространение вредоносных компьютерных программ
 - УК РФ Статья 274.1. Неправомерное воздействие на критическую информационную инфраструктуру Российской Федерации
 - УК РФ Статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей



Домашнее задание 4

1. Подобрать пароль к учетным записям СУБД Postgres, проводя онлайн-подбор паролей с помощью Сканер-ВС 6.
2. Подобрать пароль к учетным записям ОС klog и service с помощью hashcat. Информация о паролях: у klog пароль состоит только из чисел, длина пароля не превышает 10 символов, у service – пароль состоит только из букв, является английским словом, длина не превышает 8 символов.

ОТВЕТЫ

Ответ к п. 2:

postgres:postgres

root:

Ответ к п. 3:

service:service

klog:123456789

Пример решения

klog:\$1\$f2ZVMS4K\$R9XkI.CmLdHhdUE3X9jqP0:14742:0:99999:7:::
hashcat -a 3 -m 500 -increment ./file.hash ?d?d?d?d?d?d?d?d?d

```
kali@kali: ~/Desktop
File Actions Edit View Help
Host memory required for this attack: 0 MB

$1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0:123456789

Session.....: hashcat
Status.....: Cracked
Hash.Mode.....: 500 (md5crypt, MD5 (Unix), Cisco-IOS $1$ (MD5))
Hash.Target.....: $1$f2ZVMS4K$R9XkI.CmLdHhdUE3X9jqP0
Time.Started.....: Thu Apr 14 09:24:26 2022 (0 secs)
Time.Estimated...: Thu Apr 14 09:24:26 2022 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Mask.....: ?d?d?d?d?d?d?d?d [9]
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 7115 H/s (8.11ms) @ Accel:64 Loops:500 Thr:1 Vec:8
Recovered.....: 1/1 (100.00%) Digests
Progress.....: 128/1000000000 (0.00%)
Rejected.....: 0/128 (0.00%)
Restore.Point....: 0/1000000000 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:500-1000
Candidate.Engine.: Device Generator
Candidates.#1....: 123456789 → 132123123
```

План

1. Документирование в ходе проекта
2. Виды отчетов
3. Типовая структура аудиторского отчета
4. Построение отчетов в Сканер-ВС 6
5. Разбор шаблонов отчетов

Один из главных принципов аудита

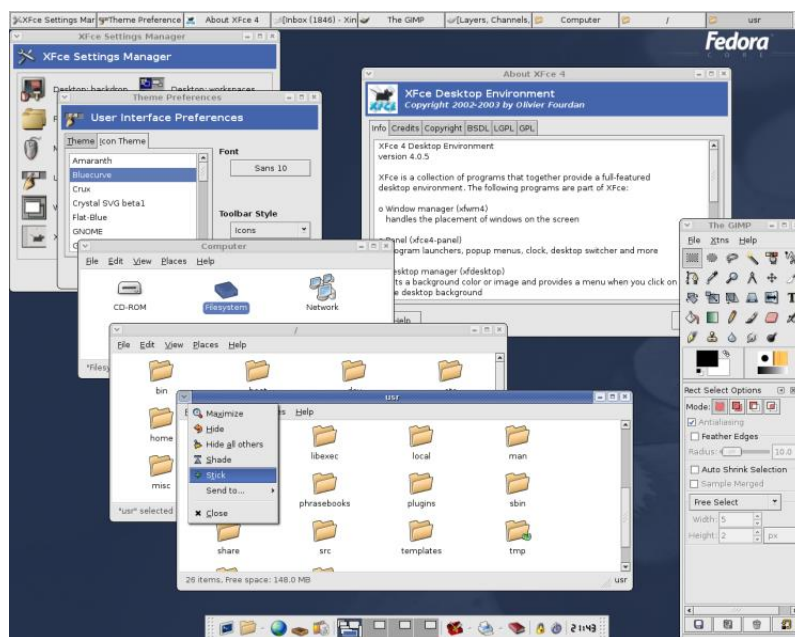
Not documented – Not done



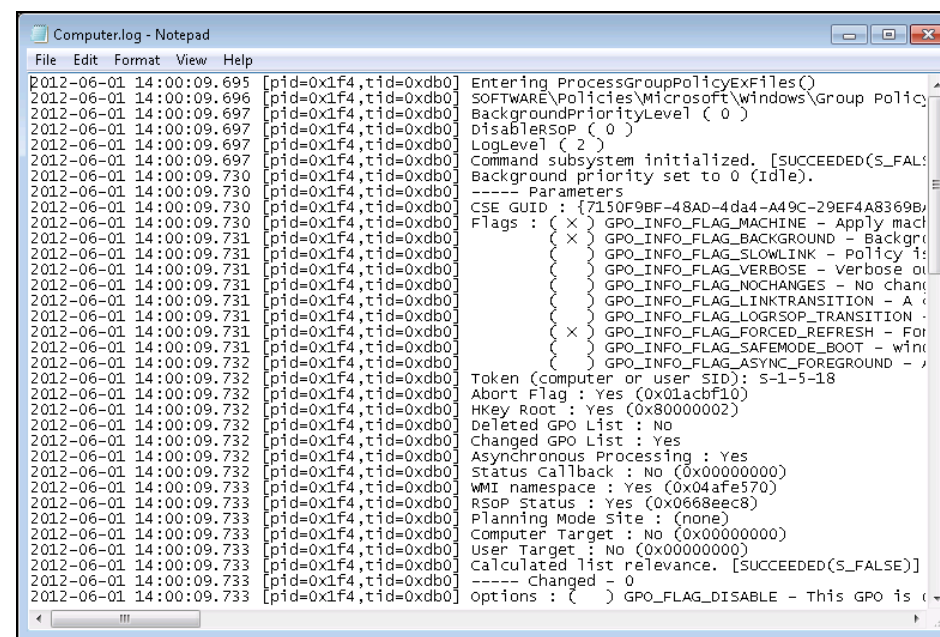
Документирование в ходе тестирования

- Цели:
 - Подтверждение выполнения шага тестирования (обнаружения уязвимости или подтверждение защищенности);
 - Сбор информации для дальнейшего анализа.

Свидетельства



Скриншоты



Журналы утилит

ВИДЫ ИТОГОВЫХ ОТЧЕТОВ

1. Описание последовательности взлома
2. Традиционный аудиторский отчет: Finding – Risk – Recommendation



Коллекция отчетов пентестеров:

<https://github.com/juliocesarfort/public-pentesting-reports>

Структура традиционного аудиторского отчета

Резюме для руководства

Основные обнаруженные проблемы и рекомендации

Границы аудита

Системы

Наш подход

Используемые методы аудита

Уязвимости

Основная часть – см. следующий слайд



Описание каждой уязвимости

Уязвимость #1

1

2

3

Обнаружение

Риск

Рекомендация

Что?
Где?
Когда?
Как?

Почему это
плохо?

Что сделать сейчас?
Как устранить
проблему?

Уязвимость #2

1

2

3

Обнаружение

Риск

Рекомендация

Книги для развития навыков написания структурированных текстов



Книга №1 по письменным коммуникациям

Искусство делового письма

Саша Карепина
Законы, хитрости, инструменты



Автор этой книги учила Тома Питерса правильно структурировать документы

Принцип пирамиды Минто

Барбара Минто
Золотые правила мышления, делового письма и устных выступлений

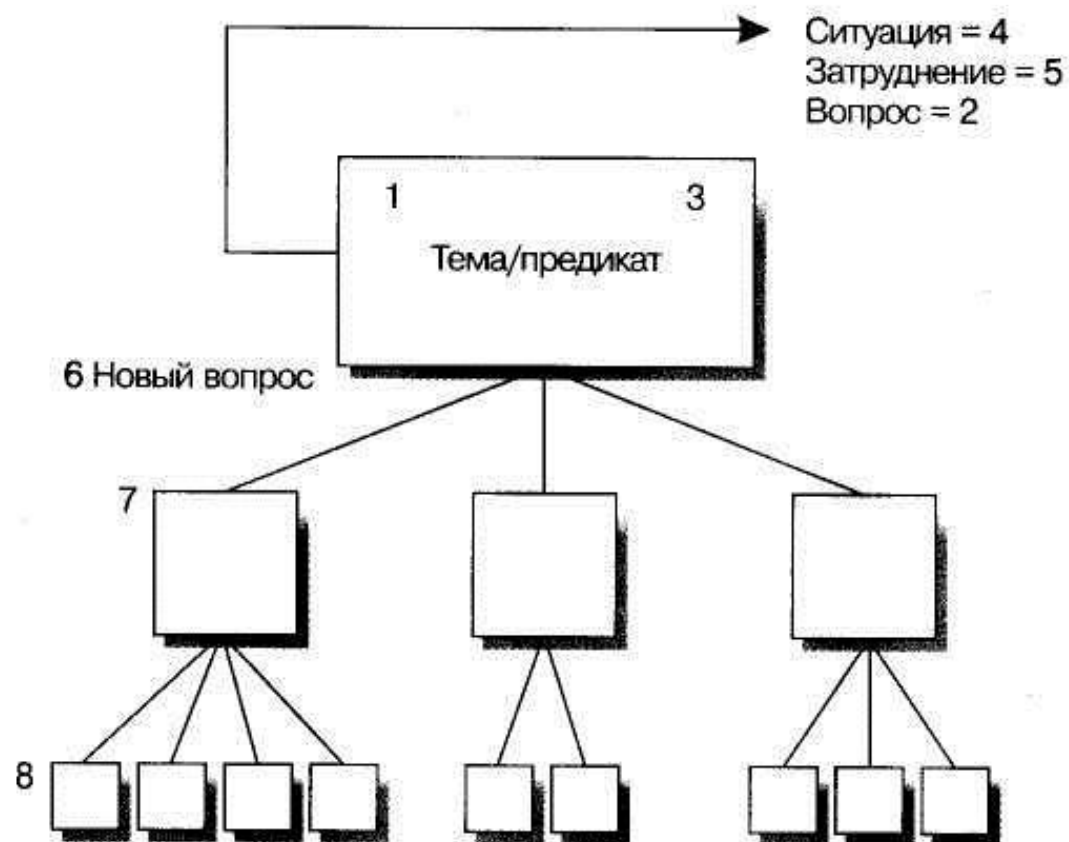


Barbara Minto
The Minto Pyramid Principle®
Logic in Writing, Thinking
and Problem Solving

Хороший перевод!

В документах следует выстраивать идеи в виде пирамиды с главной идеей на вершине

Построение пирамиды сверху вниз



Заполните верхний прямоугольник

1. Какой Предмет вы обсуждаете?
2. Какой у читателя имеется Вопрос относительно этого Предмета?
3. Каков Ответ на этот Вопрос?

Проверьте согласованность вашего ответа со структурой вводной части

4. Какова исходная Ситуация?
5. Каково Развитие Ситуации?
- (2). Следуют ли отсюда ваш Вопрос и Ответ?

Определите Главный Уровень

6. Какой Вопрос возникает у читателя далее?
7. Ваш Ответ основан на методе дедукции или индукции? Если это метод индукции, то какое родовое понятие необходимо выбрать для обобщения?

Сформулируйте вспомогательные идеи

8. На данном уровне повторите диалог «вопрос-ответ»

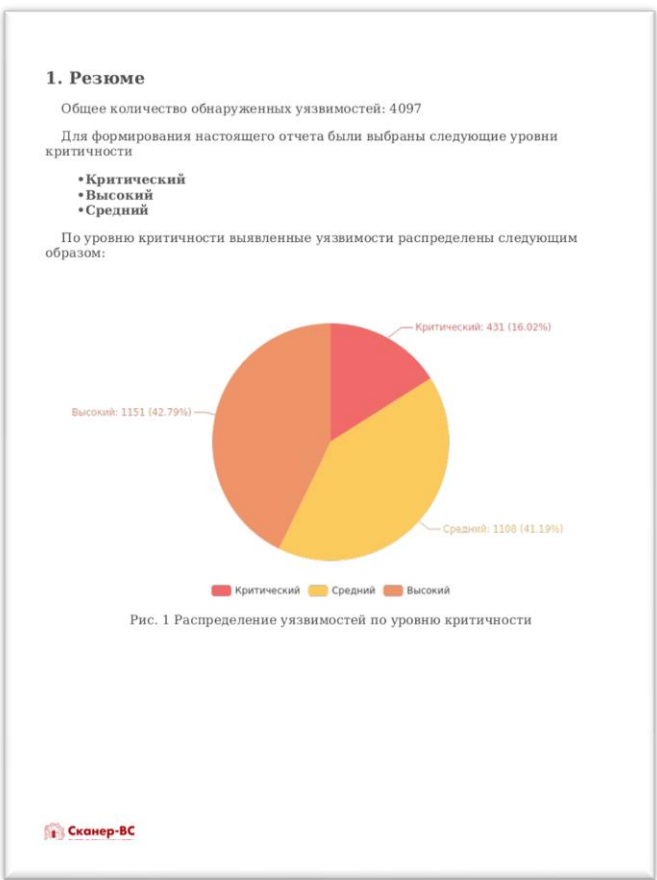
Три золотых правила пирамиды

1. Идеи любого уровня пирамиды должны обобщать идеи, сгруппированные ниже.
2. Идеи каждой отдельной группы должны быть однотипными, то есть иметь нечто общее.
3. Идеи каждой группы должны быть расположены в логической последовательности.

Логические цепочки для выстраивания идей

1. Дедуктивная (изложение материала от общего к частному: от тезиса к его доказательствам).
2. Индуктивная (изложение материала от частного к общему, от фактов к некоторой гипотезе, способ предвосхищения основания)
3. Хронологическая (первый, второй, третий).
4. Структурная (Москва, Санкт-Петербург, Сочи).
5. Сравнительная (первый по значимости, второй по значимости, третий по значимости).

Отчеты в Сканер-ВС



2. Выявленные уязвимости

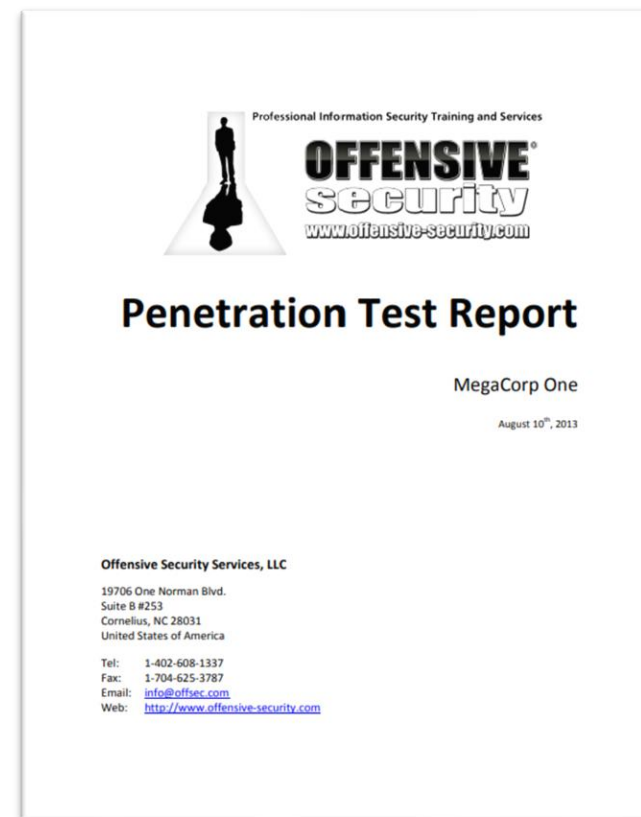
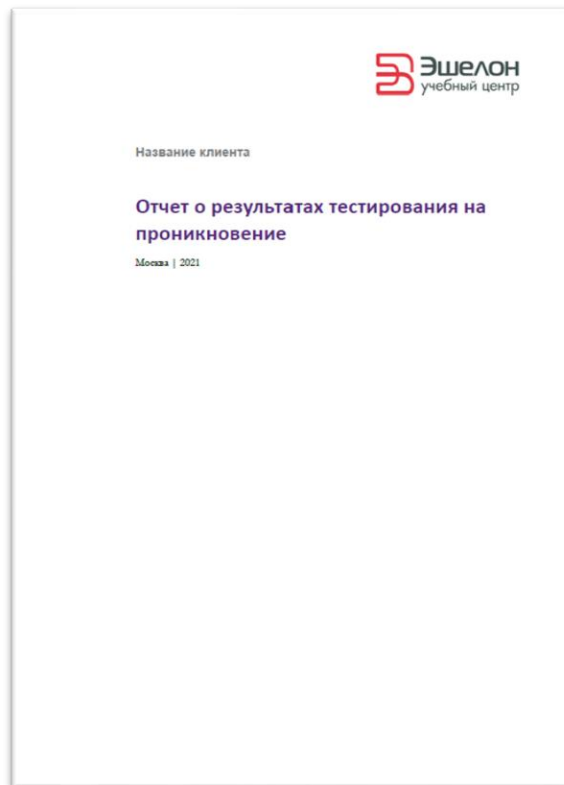
Сводная информация по обнаруженным уязвимостям с заданными при формировании отчета уровнями критичности представлена в следующей таблице:

Таблица 4. Выявленные уязвимости

№	CVE	БДУ	Уровень критичности	IP-адрес
1	CVE-2019-17006	BDU:2020-02871	Критический	192.168.1.155
2	CVE-2021-40438	BDU:2021-04820	Критический	192.168.1.155
3	CVE-2016-2148	BDU:2021-03341	Критический	192.168.1.155
4	CVE-2016-2108	BDU:2016-01176	Критический	192.168.1.155
5	CVE-2016-2182	BDU:2016-02167	Критический	192.168.1.155
6	CVE-2016-1946	BDU:2016-00512	Критический	192.168.1.155
7	CVE-2016-1944	BDU:2016-00511	Критический	192.168.1.155
8	CVE-2016-1931	BDU:2016-00510	Критический	192.168.1.155
9	CVE-2016-1930	BDU:2016-00509	Критический	192.168.1.155
10	CVE-2021-3711	BDU:2021-04570	Критический	192.168.1.155
11	CVE-2016-10229	BDU:2017-00894	Критический	192.168.1.155
12	CVE-2016-10166	BDU:2017-00763	Критический	192.168.1.155
13	CVE-2016-0799	BDU:2016-00634	Критический	192.168.1.155
14	CVE-2016-0718	BDU:2016-01470	Критический	192.168.1.155
15	CVE-2016-0705	BDU:2016-00631	Критический	192.168.1.155
16	CVE-2016-2842	BDU:2016-00635	Критический	192.168.1.155

Отчеты по тестированию на проникновение

20



<https://github.com/juliocesarfort/public-pentesting-reports>

Домашнее задание 5

1. Написать раздел отчета о выявленной уязвимости в vsftpd на metasploitable 2.

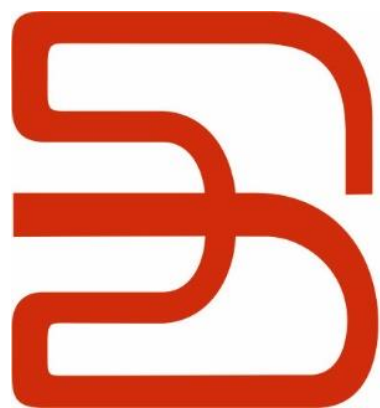
Echelon Eyes

Echelon Eyes



@ECHELONEYES

- Материалы курса: презентации, видео
- Новости об уязвимостях, инцидентах, эксплойтах, изменениях в нормативной базе



Эшелон

комплексная безопасность